DevSecOps tools

DevSecOps tools help enforce security

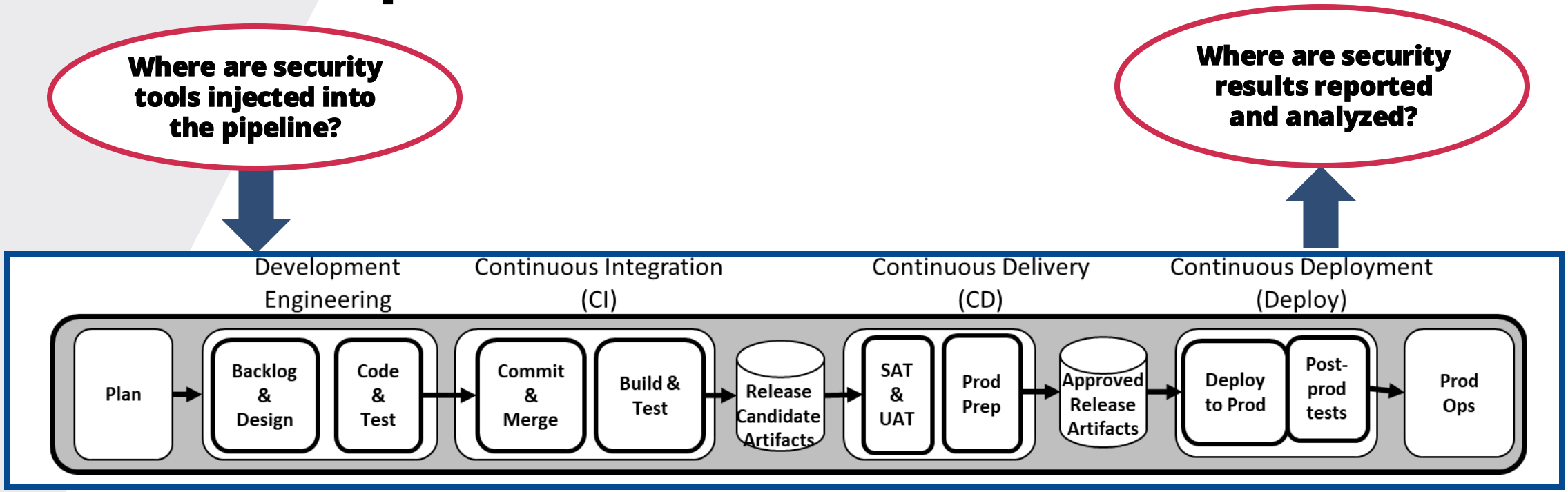
DevSecOps tools help securing through:	Good tips for enforcing security:
• fixing vulnerabilities • identifying and reducing attack surfaces • conducting personnel training • enforcing policy.	• regular external penetration tests • telemetry delivered directly to teams • user credentials enforced • immutable infrastructure to lock production systems.



Source: https://medium.com/lotus-fruit/implementing-continuous-security-for-microservices-and-kubernetes-640d66e2460

Copyright© 2025 PeopleCert International Ltd.

DevSecOps toolchains



Source: *Engineering DevOps by Marc Hornbeek*
https://mybook.to/engineeringdevops

Tools are needed to cover risky functional and non-functional security requirements. Ensure relevant security tests are executed as early as possible in the pipeline (Shift-left). Security results should be validated to gate promotion to next stage.

Copyright© 2025 PeopleCert International Ltd.

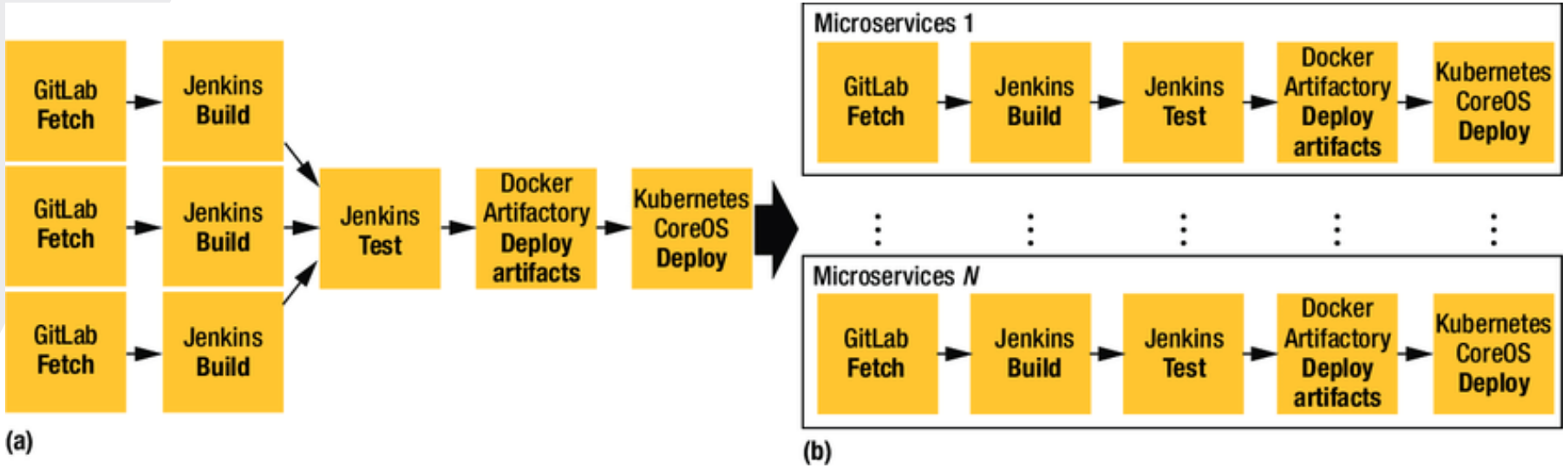
Version management tools

Securing the repository

- Trusted repos; access, authentication.
- Consider exposure and determine protection needs.
- Protect/manage access credentials.
- Remove secrets from code.
- Review changes.
- Have frequent back-ups (3 sources, 2 media, 1 offline).

Code repository (repo)

- Should be a single source of truth.
- Source code can be vulnerable to several risks:
  - IP protection
  - embedded secrets
  - increased attack surface.



Source: *Balalae, A. Heydarnoori, A., and Jamshidi, P. (2016) Microservices architecture enables DevOps. IEEE Software. 1-12*
https://www.researchgate.net/publication/298902672_Microservices_Architecture_Enables_DevOps_an_Experience_Report_on_Migration_to_a_Cloud-Native_Architecture

Copyright© 2025 PeopleCert International Ltd.

DevSecOps repositories

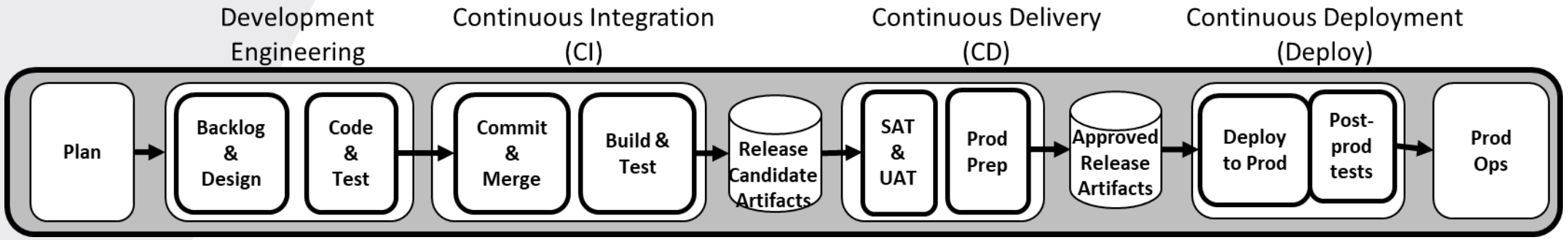
- **Pipelines can require multiple repositories.**
- **Some code is local, some calls externally**
  - Bitbucket
  - GitHub
  - Azure repos.
- **Check documentation for preferred languages and tools**
  - YML – YAML – YAML is not markup language.
  - Identify pipeline needs.
- **Working with visual tools can accelerate growth.**
- **When forking branches (creating a local copy)**
  - Protect secrets.
  - Consider manual builds.
  - Consider using enterprise agents to sponsor build.



Source: https://www.practical-devsecops.com/role-of-repositories-in-software-supply-chain-security/

Copyright© 2025 PeopleCert International Ltd.

DevSecOps testing tools



Threat modelling

Software Composition Analysis (SCA)

Static Application Security Testing (SAST)

Dynamic Application Security Testing (DAST)

Interactive Application Security Testing (IAST)

Fuzz testing

Penetration testing automation

API security testing

Cloud security testing

Security compliance validation

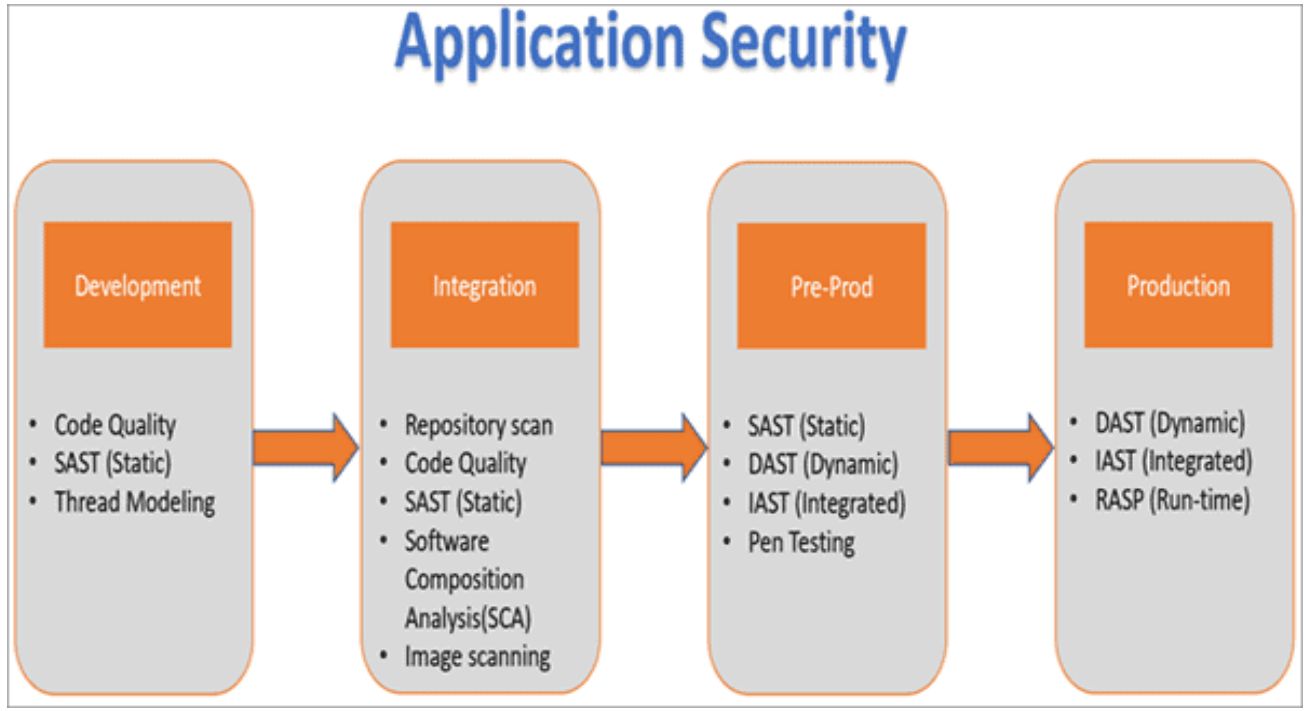
Vulnerability scanning

Copyright© 2025 PeopleCert International Ltd.

Security scanning tools

What to scan for?

- Composition analysis and Software bill of materials (SBOM) (For example, Syft, CycloneDX)
- Source code vulnerabilities (For example, SonarQube, Checkmarx)
- Licensing risks (For example, FOSSA, Black Duck)
- Containers vulnerabilities (For example, Trivy, Aqua)
- Artifact vulnerabilities (For example, Jfrog Xray, Nexus IQ)
- Dependency Scans (Snyk, OWASP)
- Dynamic scanners (For example, OWASP Zap, Burp Suite).



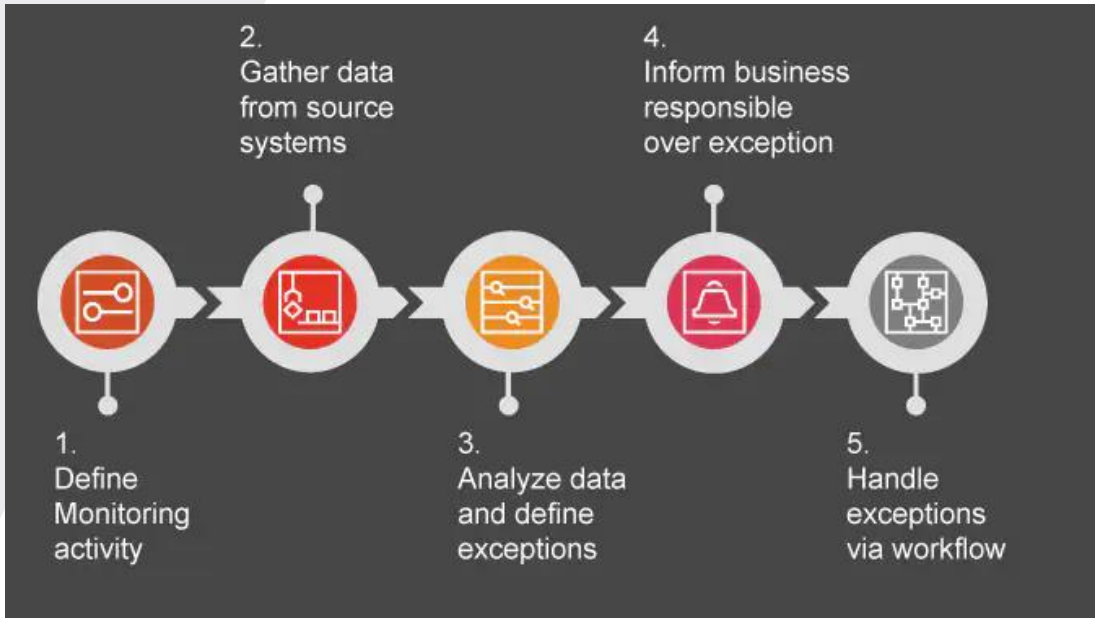
Source: https://www.softwaretestinghelp.com/differences-between-sast-dast-iast-and-rasp/

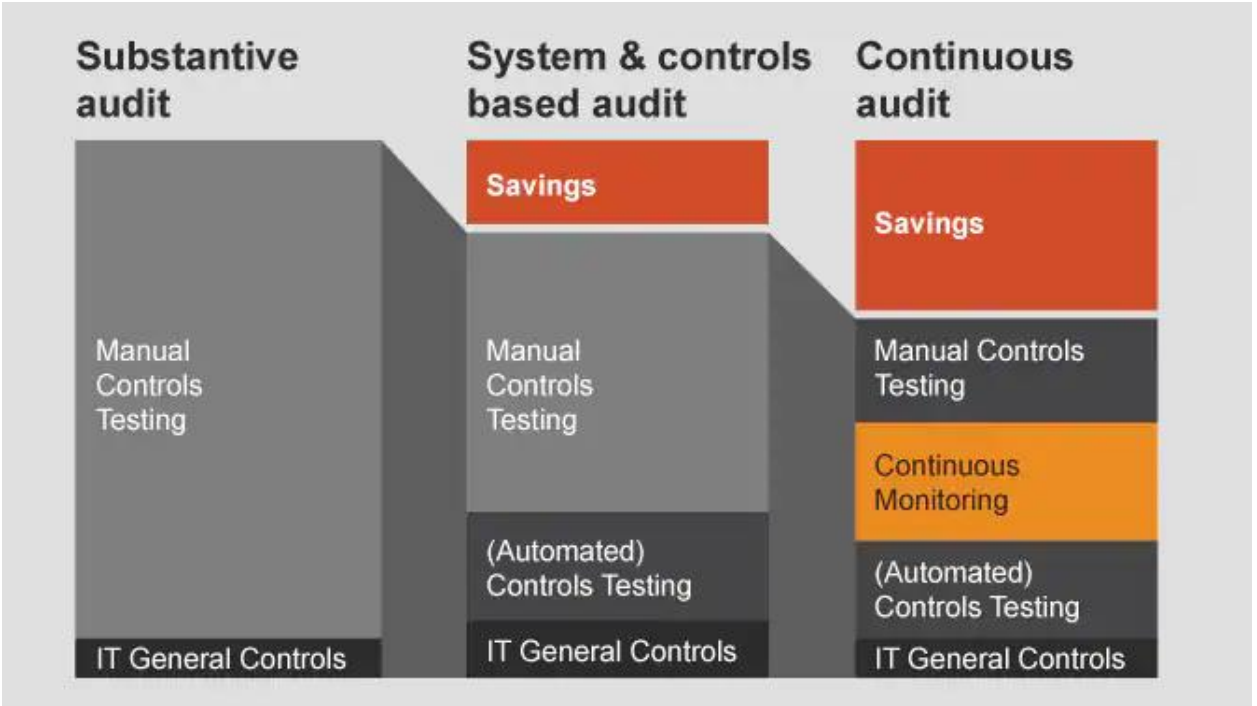
Copyright© 2025 PeopleCert International Ltd.

DevSecOps monitoring tools

Monitoring tools link security and Ops with performance reports:

- Link outputs to audit inputs.
- Reinforce it general controls.
- Verify policy outcomes.





Example tools: Datadog, Splunk

Source: https://www.pwc.nl/en/services/audit-assurance/continuous-monitoring-platform.html

Copyright© 2025 PeopleCert International Ltd.

Telemetry options

Telemetry

the automated communication processes from multiple data sources (Sumo logic).

CI/CD telemetry reports facts:

- Creates shared observability.
- Collects metrics, tracks gates, monitors risks.



Copyright© 2025 PeopleCert International Ltd.

Do not forget about databases

Data testing

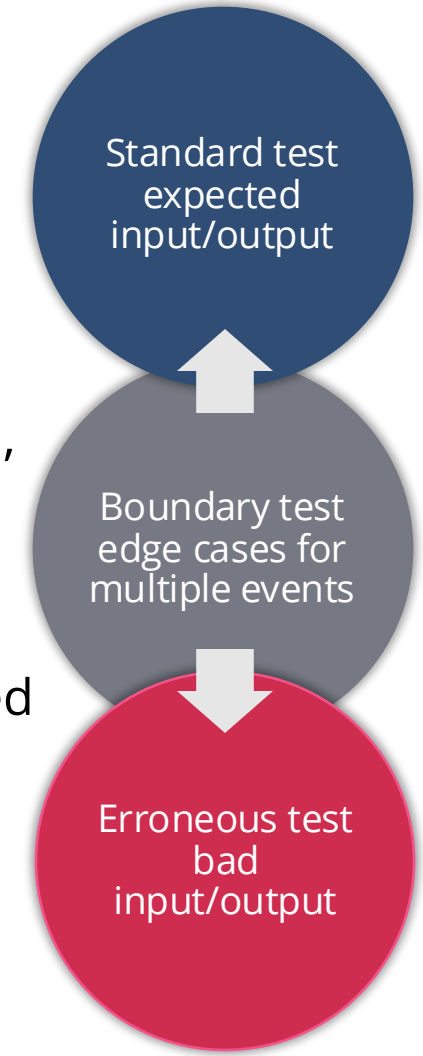
- Test standard, erroneous, and boundary cases.
- Work through Extract, Transform, and Load (ETL) processes.

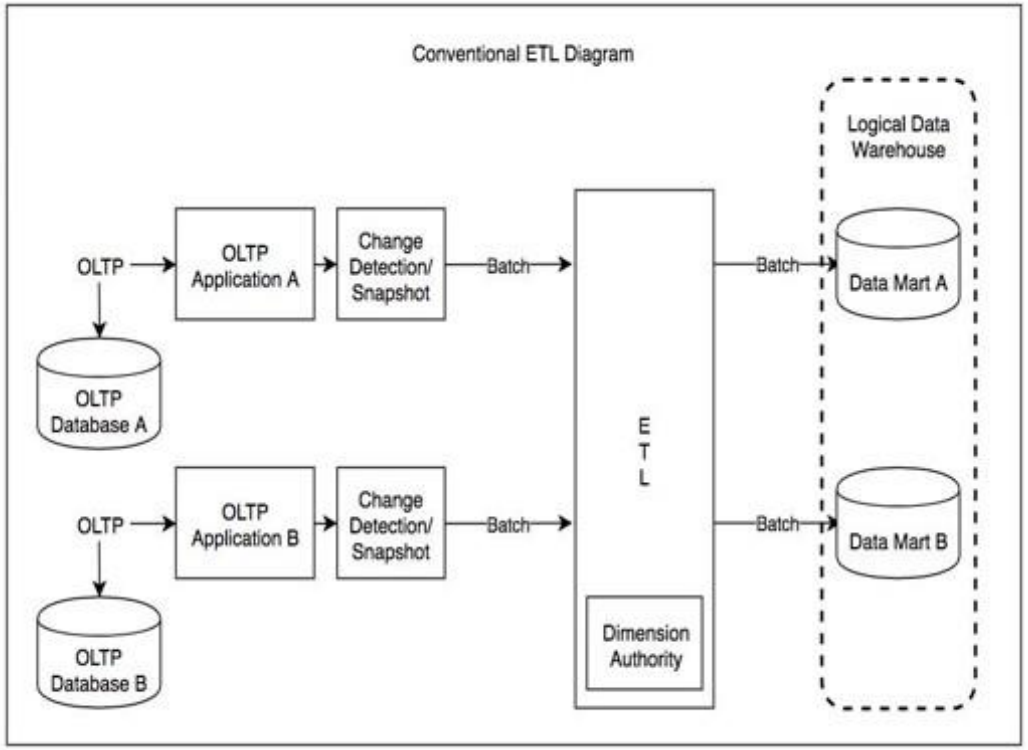
End-to-End testing

- Measure user functions, conditions, and test cases.
- Apply key principles to test-driven development.
- Achieve the end state for automated testing.

Performance testing

- What is the expected standard?
- Most performance tests cost.





Source: https://www.amazon.com/Data-Warehouse-ETL-Toolkit-Techniques-Extracting/dp/0764567578

Copyright© 2025 PeopleCert International Ltd.

Case story: Implementing a DevSecOps pipeline in the healthcare sector

Aggregation of vulnerability findings in Security Hub provided opportunities to automate the remediation. This also reduced the burden on operations and security teams because they could now address the vulnerabilities from a single pane of glass instead of logging into multiple tool dashboards.

Taashee helped a multinational healthcare giant create an end-to-end AWS DevSecOps CI/CD pipeline with open-source SCA, SAST and DAST tools, continuous testing, continuous logging and monitoring, auditing and governance, and operations. The vulnerability findings had to be aggregated in the Security Hub as a single pane of glass.



Copyright© 2025 PeopleCert International Ltd.

Case story: DevOps with Cloudbees and Perfecto Mobile | Benefits

Yoram Mizrachi, PM CTO



- Gives a comparative analysis of two different corporate approaches.
- Shows challenges still exist in native pipelines versus recently adopted outcomes.



Copyright© 2025 PeopleCert International Ltd.